

İSTANBUL DENEYAP TEKNOLOJİ ATÖLYESİ

Ders Saatleri : 09.00 - 13.00 - Orta Sabah Grubu (Sınıfdan) - (29 Haziran-8 Temmuz Hafta İçi)

Ders Saatleri : 13.30 - 17.30 - Orta Öğle Grubu (Sınıfdan) - (29 Haziran-8 Temmuz Hafta İçi)



SİBER GÜVENLİK DERSİ

3.Ders: Parolalar



T3 DENEYAP EĞİTMENİ (Hazırlayan ve Sunan): Muhammed Emin Korkunç

(Bilgisayar Mühendisi)

Bu sunumun kopyalanması, paylaşılması ve yazılı izinsiz kullanımı KESİNLİKLE YASAKTIR.

Muhammed Emin Korkunç | muhammedemin.korkunc@gmail.com | linkedin.com/in/muhammed-emin-korkunc-100ba2215 | github.com/muhammedkorkunc

Sabah Grubu

- 09.00 - 09.50: 1. Ders
- 09.50 - 10.00: 1. Mola
- 10.00 - 10.50: 2. Ders
- 10.50 - 11.00: 2. Mola
- 11.00 - 11.50: 3. Ders
- 11.50 - 12.00: 3. Mola
- 12.00 - 13.00: 4. Ders

Öğle Grubu

- 13.30 - 14.20: 1. Ders
- 14.20 - 14.30: 1. Mola
- 14.30 - 15.20: 2. Ders
- 15.20 - 15.30: 2. Mola
- 15.30 - 16.20: 3. Ders
- 16.20 - 16.30: 3. Mola
- 16.30 - 17.30: 4. Ders



1- Parolalar Giriş

Parola (password) kelimesi yerine şifre kelimesinin kullanıldığını sıkça duyabiliriz (örn. e-posta şifresi, e-devlet şifresi, tek kullanımlık şifre vb.). Günlük hayatta bu kullanım ciddi bir sorun oluşturmasa da, parola demek daha doğrudur çünkü siber güvenlikte şifre (cipher) terimi şifreleme algoritmalarını ifade eder ve parola kavramının şifreleme ile doğrudan bir ilgisi yoktur.

Parolanız var mı?

Parola ile nerelere giriş yapıyorsunuz?

Parolalarınızı nasıl belirliyorsunuz?

Belli zamanlarda parolanızı değiştiriyor musunuz?

Parolaları kaç karakterden oluşturuyorsunuz?

Parolalara doğum yeri ya da doğum tarihini vermek sizce doğru mudur?

Parola oluştururken belli bir mantık, yapı ya da yol takip ediyor musunuz?

2- PAROLA KAVRAMI

Parola, bir kişinin erişim yetkisini doğrulamak için kullanılır. Örneğin, bir askeri alana veya kışlaya girmek isteyen birine kapıdaki nöbetçi asker parola sorabilir. Geleneksel parolalar bir kelime veya cümle olabilirken, günümüzde yaygın olarak bilgisayar sistemlerine giriş için kullanılan parolalar genellikle farklı bir yapıya sahiptir.

Tarihte parola kullanımı, genellikle gizli veya kısıtlı bir bölgeye erişim için sadece belli kişilerce bilinen bir kelime veya cümle (örn. “açıl susam açıl”) söyleme şeklindeyken, günümüz sistemlerinde her kullanıcının kendine özel kullanıcı adı ve parolası bulunmaktadır.

Bilgisayar sistemlerinde kullanılan parola bir dizi sembolden oluşur. Bu semboller küçük harf, büyük harf, rakam, noktalama işareti ve diğer özel semboller (tire, alt çizgi, yıldız vb.) olabilir. Bir paroladaki sembollerin sayısı ve çeşitliliği parolanın gücü açısından önemlidir. Bir saldırgan tarafından tahmin edilmesi zor olan parolalar daha güçlü kabul edilir.

3- PAROLALARIN SAKLANMASI

Parolalar erişim sağlanacak sistem üzerindeki özel bir dosya içerisinde, hash işleminden geçirilmiş halde saklanırlar. Parolaların orijinal hallerinin sistemde tutulmamasındaki amaç, sisteme sızmış olan bir saldırganın parolaları ele geçirmesini engellemektir. Hash fonksiyonları tek yönlü (geri döndürülemez) fonksiyonlar oldukları için, saklanan hash değerlerinden parolaya ulaşmak mümkün değildir.



Bu sunumun kopyalanması, paylaşılması ve yazılı izinsiz kullanımı KESİNLİKLE YASAKTIR.

4- PAROLA KIRMA SALDIRILARI

Bir parolanın kırılma zorluğunu belirleyen birçok etken vardır. Bunlardan bazıları aşağıda tartışılmaktadır.

Uzunluk: Kısa parolalar uzun parolalara göre genellikle daha kolay kırılır.

İçerdiği semboller: Sadece harf veya sadece rakam içeren, özel sembol içermeyen parolalar daha kolay kırılır.

Anlamlı olup olmaması: Belli bir anlama sahip olan parolalar (örn. kelime, cümle, tarih) daha kolay kırılır.

Uzun bir parola kısa bir parolaya göre daha zayıf olabilir. Örneğin, harf, rakam ve özel sembol içeren 6 karakterli bir parola, 123456789 gibi 9 karakterli bir parolaya göre çok daha güçlüdür.

Bu sunumun kopyalanması, paylaşılması ve yazılı izinsiz kullanımı KESİNLİKLE YASAKTIR.

5- PAROLA SALDIRISI TÜRLERİ

Parola Saldırısı Türleri Aşağıda yaygın parola saldırılarından bazıları verilmiştir (Subangan & Senthooan, 2019).

Kaba kuvvet tahmin: Belli bir sırayla bütün olası parolaların denenmesine dayalı saldırı türüdür. Bu saldırıda yapılacak tahmin sayısı, olası parola sayısı ile orantılıdır. En basit ama en yavaş parola saldırısı türüdür.

Sözlük saldırısı: Önceden oluşturulmuş bir sözlükteki kelimeleri ve bunların kombinasyonlarını parola olarak denemeye dayalı saldırı türü. Birçok insanın parolalarının anlamlı kelimelere dayandığı gözleminden faydalanılır.

Popüler parola deneme: İnsanların yaygın olarak kullandığı bilinen parolaları denemeye dayalı saldırı türüdür. Sözlük saldırısıyla veya kaba kuvvet tahminle birleştirilebilir, yani popüler parolalar başta denenerek başarısız olunması durumunda diğer saldırıya geçilebilir.

Kişiyeye özel saldırı: Bir kişiyle ilgili bilgiler (doğum tarihi, memleketi, çocuklarının adları vb.) dikkate alınarak yapılan parola tahminlerine dayalı saldırı türüdür.

Sosyal mühendislik: Kişileri kandırarak parolalarını söylemelerini veya saldırganın göreceği bir yere yazmalarını sağlamaya çalışan saldırı türüdür. Sosyal mühendislik, 5. haftada daha ayrıntılı olarak ele alınacaktır.

6- PAROLA SEÇİMİ

Güçlü parola seçmek için bazı hususlara dikkat etmek gerekmektedir.

-Parola olarak anlamlı bir kelime, isim, cümle, tarih vb. seçilmemelidir.

-Bir kelimenin veya ismin başına/sonuna bir veya birkaç rakam eklenerek parola oluşturulmamalıdır.

-Parola yeterince uzun olmalıdır. Birçok sistemde parola uzunluğu için bir alt sınır vardır (en az 8, en az 10 gibi). Genellikle parola uzadıkça kırılması zorlaşır.

-Parolada sembol çeşitliliği olmalıdır. Bir başka deyişle küçük harfler, büyük harfler, rakamlar, noktalama işaretleri ve diğer özel semboller birlikte bulunmalıdır.

-Parola tercihen kolay hatırlanır olmalıdır. Eğer parola akılda kalmıyorsa kişi parolayı bir yere yazmak isteyebilir, bu da güvenli değildir çünkü parolanın çalınma ihtimalini doğurur. Parola herhangi bir yere yazılmamalıdır.

Hem güçlü hem de kolay hatırlanır bir parola oluşturmak karmaşık ve özen gerektiren bir iştir.

Güvenli parola oluşturmakta kullanılabilecek bir yöntem, sizin aklınızda kalacak ama kolay kolay tahmin edilemeyecek uzunca bir cümle seçip o cümleyi oluşturan kelimelerden bazı harfleri (örneğin her kelimenin ilk iki harfi veya ilk ve son harfleri) birleştirerek parola oluşturmaktır.

Bunu yaparken bazı harfleri büyük harf yapmak, bazılarını da bir şekilde rakama veya özel karaktere çevirmek parolayı güçlendirir.

8- PAROLA SEÇİMİ

Örnek: Kafamızdan bir cümle uyduralım, sonra her kelimenin ilk ve son harflerini alalım.

Bayılırım biber dolmasına Perşembeleri kahvaltıda BmbrdaPika Bu cümlelerin garipliği akılda kalıcılığını artıracaktır.

Şimdi bazı harfleri kendilerine benzeyen rakam ve özel karakterlerle değiştirelim.

BmbrdaPika -> 8m6rdaP!ka

Yukarıdaki parola hem akılda kalıcıdır (parolayı hemen hatırlayamasak da kolayca türetebiliriz) hem de tamamen rastgele üretilen 10 karakterli bir parolaya yakın düzeyde güvenlik sağlar, yani kırılması oldukça zordur.

Parolanın ne kadar güçlü olduğunu düşünürseniz düşünün, parolaları sık sık değiştirmek önemlidir

Bu sunumun kopyalanması, paylaşılması ve yazılı izinsiz kullanımı KESİNLİKLE YASAKTIR.

Muhammed Emin Korkunç | muhammedemin.korkunc@gmail.com | linkedin.com/in/muhammed-emin-korkunc-100ba2215 | github.com/muhammedkorkunc



a. 4 karakterden oluşan ve sadece rakamlar içeren kaç tane farklı parola olabilir?

Muhammed Emin Korkunç

Seçenek sayısı: 10 tane rakam (0, 1, 2, 3, 4, 5, 6, 7, 8, 9)

Uzunluk: 4

Hesaplama: $10 \times 10 \times 10 \times 10 = 10^4$

Cevap: 10.000 farklı parola

b. 6 karakterden oluşan ve sadece İngiliz alfabesinden küçük harfler içeren kaç tane farklı parola olabilir?

Muhammed Emin Korkunc

Seçenek sayısı: 26 tane küçük harf

Uzunluk: 6

Hesaplama: 26^6

Cevap: 308.915.776 farklı parola

Muhammed Emin Korkunç

c. 8 karakterden oluşan ve İngiliz alfabesinden küçük veya büyük harfler içeren kaç tane farklı parola olabilir?

Muhammed Emin Korkunc

Seçenek sayısı:

26 küçük + 26 büyük = 52 farklı harf

Uzunluk: 8

Hesaplama: 52^8

Cevap: 53.459.728.531.456 farklı parola

d. 10 karakterden oluşan ve sadece rakamlar içeren kaç tane farklı parola olabilir?

Muhammed Emin Korkunç

Seçenek sayısı: 10 tane rakam

Uzunluk: 10

Hesaplama: 10^{10}

Cevap: 10.000.000.000 (10 Milyar) farklı parola

Muhammed Emin Korkunç

e. 10 karakterden oluşan ve rakamlar veya İngiliz alfabesinden küçük harfler içeren kaç tane farklı parola olabilir?

Muhammed Emin Korkunç

Seçenek sayısı: 10 rakam + 26 küçük harf = 36

farklı karakter

Uzunluk: 10

Hesaplama: 36^{10}

Cevap: 3.656.158.440.062.976 farklı parola

f. 12 karakterden oluşan ve sadece İngiliz alfabesinden küçük harfler içeren kaç tane farklı parola olabilir?

Muhammed Emin Korkunç

Seçenek sayısı: 26 tane küçük harf

Uzunluk: 12

Hesaplama: 26^{12}

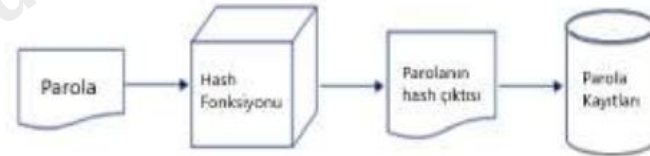
Cevap: 95.428.956.661.682.176 farklı parola

Muhammed Emin Korkunç

Bu etkinlik için John the Ripper adlı uygulama kullanılacaktır.

Bu uygulama yardımıyla parola tahmin saldırıları yaparak çeşitli parolaları ne kadar sürede kırabildiklerini görülecektir.

Ön bilgi: Kullanıcı parolaları güvenlik nedeniyle sistemde düz metin olarak tutulmaz. Bunun yerine parola Şekil 1'dekine benzer bir şekilde hash işleminden geçirildikten sonra saklanır.



Sekil 1. Parolaların sistemde saklanması

Not: Gerçek sistemlerde parola hash fonksiyonuna girmeden önce tuz (salt) denen bir değer ile birleştirilerek hash eşleştirme tabanlı bazı parola saldırılarına karşı direnç sağlanır.

Bu uygulamada faydalanılacak aracın kullanım örneği aşağıda verilmiştir.

Komutu çalıştırmadan önce öğrenciler kelime listesi (password.lst) ve parola hash listesi (unshadowed.txt) dosyalarını incelemelidir.

Bir kelime listesi yani wordlist kullanarak
(`--wordlist=/usr/share/john/password.lst`) ve tanımlı karakter
değiştirme kurallarını uygulayarak (`--rules`), verilen bir dosya
(`unshadowed.txt`) içindeki parola hash değerlerini kırarak parolaları
açığa çıkartmak için komut:

```
root@kali:~# john --wordlist=/usr/share/john/password.lst --rules unshadowed.txt
```

```
Warning: detected hash type "sha512crypt", but the string is also recognized as  
"crypt"
```

```
Use the "--format=crypt" option to force loading these as that type instead
```

```
Loaded 1 password hash (sha512crypt [64/64])
```

```
toor (root)
```

```
guesses: 1 time: 0:00:00:07 DONE (Mon May 19 08:13:05 2014) c/s: 482 trying:  
1701d - andrew
```

```
Use the "--show" option to display all of the cracked passwords reliably
```

Bu sunumun kopyalanması, paylaşılması ve yazılı izinsiz kullanımı KESİNLİKLE YASAKTIR.

24- PAROLA KIRMA SALDIRISI UYGULAMASI

Bu etkinlikte her öğrenci kendi kelime listesini, bir başka deyişle denenecek parola listesini, oluşturacak ve unshadowed.txt içindeki parola hash değerlerini kırmaya çalışacaktır. Yukarıda gösterilen john komutuna girdi olarak verilen unshadowed.txt dosyasını oluşturmak için aşağıdaki komut kullanılabilir: Çalışma kolaylığı açısından masaüstüne veya boş bir klasöre geçiş yapabilirsiniz:

```
cd ~/Desktop
```

unshadowed . txt Dosyasını Oluşturun

Linux sistemlerde kullanıcı bilgileri ile parola hash'leri güvenlik nedeniyle farklı dosyalarda (/etc/passwd ve /etc/shadow) tutulur. John'un bu hash'leri okuyabilmesi için bu iki dosyayı birleştirmemiz gerekir.

```
sudo unshadow /etc/passwd /etc/shadow > unshadowed.txt
```

```
(kali㉿kali)-[~]  
$ sudo unshadow /etc/passwd /etc/shadow > unshadowed.txt  
[sudo] password for kali:  
Created directory: /root/.john
```

Not: Bu komut, sistemdeki tüm kullanıcıların hash bilgilerini birleştirerek bulunduğunuz dizinde unshadowed . txt adında bir dosya oluşturur.

25- PAROLA KIRMA SALDIRISI UYGULAMASI

Saldırıyı Başlatın (Wordlist ve Kurallar ile)

Sistemin varsayılan kelime listesini (password.lst) ve harf/rakam değiştirme kurallarını (--rules) kullanarak verilen ana komutu çalıştırın:

john --wordlist=/usr/share/john/password.lst --rules unshadowed.txt

Kırılan Parolaları Görüntüleme

```
(kali@kali)-[~]  
$ john --wordlist=/usr/share/john/password.lst --rules unshadowed.txt  
Created directory: /home/kali/.john  
Using default input encoding: UTF-8  
No password hashes loaded (see FAQ)
```

John the Ripper arka planda eşleşen parolaları bulduğunda ekrana yansıtacaktır (toor (root) çıktısı gibi). Eğer işlemi daha sonra kontrol etmek veya kırılan tüm parolaları toplu görmek isterseniz şu komutu kullanabilirsiniz:

john --show unshadowed.txt

26- PAROLA KIRMA SALDIRISI UYGULAMASI

Olası Hata Durumunda (Format Zorlama)

Eğer yukarıdaki komutu çalıştırdığınızda terminalde uyarısı geçilen *"No password hashed loaded"* veya benzeri bir format algılama hatası alırsanız, John'a hash formatını elle belirtmeniz gerekir.

Bunun için şu alternatif komutu deneyin:

```
john --format=crypt --wordlist=/usr/share/john/password.lst --rules unshadowed.txt
```

```
(root@kali) ~/home/kali
john --format=crypt --wordlist=/usr/share/john/password.lst --rules unshadowed.txt
Using default input encoding: UTF-8
Loaded 1 password hash (crypt, generic crypt(3) [?/64])
Cost 1 (algorithm [1:descrypt 2:md5crypt 3:sunmd5 4:bcrypt 5:sha256crypt 6:sha512crypt]) is 0 for all loaded hashes
Cost 2 (algorithm specific iterations) is 1 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:01 0.09% (ETA: 02:13:12) 0g/s 61.14p/s 61.14c/s 61.14C/s piglet..knight
0g 0:00:00:02 0.14% (ETA: 02:19:03) 0g/s 77.10p/s 77.10c/s 77.10C/s lacrosse..pumpkin
0g 0:00:00:06 0.38% (ETA: 02:21:59) 0g/s 100.0p/s 100.0c/s 100.0C/s sniper..bigben
0g 0:00:00:07 0.43% (ETA: 02:22:57) 0g/s 101.8p/s 101.8c/s 101.8C/s bigdog..francesco
0g 0:00:00:08 0.47% (ETA: 02:23:44) 0g/s 100.2p/s 100.2c/s 100.2C/s francine..me
0g 0:00:00:17 0.95% (ETA: 02:25:29) 0g/s 104.8p/s 104.8c/s 104.8C/s susan1..121212
0g 0:00:00:18 1.00% (ETA: 02:25:44) 0g/s 104.4p/s 104.4c/s 104.4C/s 1234qwer..babygirl
0g 0:00:00:19 1.04% (ETA: 02:25:58) 0g/s 105.1p/s 105.1c/s 105.1C/s pretty..celtic
0g 0:00:00:20 1.14% (ETA: 02:24:54) 0g/s 106.0p/s 106.0c/s 106.0C/s katrina..karla
0g 0:00:00:21 1.19% (ETA: 02:25:08) 0g/s 106.1p/s 106.1c/s 106.1C/s chacha..jazmin
0g 0:00:00:22 1.23% (ETA: 02:25:21) 0g/s 107.4p/s 107.4c/s 107.4C/s rosita..help
0g 0:00:00:23 1.33% (ETA: 02:24:29) 0g/s 109.1p/s 109.1c/s 109.1C/s 10snel..nermal
0g 0:00:00:24 1.38% (ETA: 02:24:42) 0g/s 109.3p/s 109.3c/s 109.3C/s nina..Joanna
0g 0:00:00:25 1.42% (ETA: 02:24:54) 0g/s 109.5p/s 109.5c/s 109.5C/s Johnson..buzz
0g 0:00:00:26 1.47% (ETA: 02:25:05) 0g/s 109.3p/s 109.3c/s 109.3C/s c00per..gator1
0g 0:00:00:27 1.52% (ETA: 02:25:16) 0g/s 109.1p/s 109.1c/s 109.1C/s gibbons..mobydick
kali (kali)
1g 0:00:00:27 DONE (2026-07-01 01:56) 0.03580g/s 109.9p/s 109.9c/s 109.9C/s gibbons..mobydick
Use the "--show" option to display all of the cracked passwords reliably
Session ID: 2026-07-01 01:56
```

Bu sunumun kopyalanması, paylaşılması ve yazılı izinsiz kullanımı KESİNLİKLE YASAKTIR.

Bazı tavsiyeler : Kullanıcılar tarafından yaygın kullanılan parolaların neler olduğu düşünülüp bunlar listeye eklenebilir.

Bu parolaların başına veya sonuna rakam veya başka sembol ekleme, kelimeleri birleştirme gibi yöntemlerle başka parolalar üretilip liste genişletilebilir.

Denenen bir liste başarıya ulaşamazsa liste daha da genişletilebilir. Denemeler yapılabilir. Etkinliğin sonunda, parola kırmada en kolay başarıya ulaştıran yöntemin ne olduğu üzerine tartışılır.

Bu bölümde her öğrenci bağımsız olarak bir rastgele parola üretme programı tasarlayıp kodlayacaktır.

Muhammed Emin Korkunç

Girdi: Parola uzunluğu

Çıktı: Rastgele üretilmiş parola

Program, verilen bir uzunlukta rastgele parola üretecektir. Rastgele parola içinde en azından büyük-küçük harfler ve rakamlar bulunabilmelidir. Ek olarak her öğrenci kendi seçeceği bazı özel sembolleri de dâhil edebilir. Program her çalıştığında farklı bir rastgele parola üretmelidir. Programı tasarlamak, yazmak ve test etmek gerekir.

Bu programı başarıyla tamamlayan öğrenciler, kodlarını güncelleyerek aşağıdaki özellikleri ekleyebilirler:

Parola içinde en az 1 büyük harf olduğunu garanti etme,
Parola içinde en az 1 özel sembol olduğunu garanti etme,
Parola içinde en az 1 rakam olduğunu garanti etme,
Girdi olarak verilen uzunluğu minimum olarak kabul edip daha uzun parola üretebilme

Etkinliğin sonunda süre uygunsa programı tamamlayan her öğrenci programının çalışmasını eğitmene yapacağı bir demo ile gösterebilir. Ayrıca, öğrencilerin kaynak kodlarını eğitmene göndermesi ve eğitmenin ders sonrasında çözümlerin uygunluğunu değerlendirmesi faydalı olacaktır.

Sizce yazdığınız rastgele parola üretme programı yeterince güçlü parolalar üretebilir mi?

Daha güçlü parola üretmesi için neler yapılabilir?

Verilen bir parolanın güçlü olup olmadığını değerlendiren bir program yazmak isterseniz nasıl bir yaklaşım izlersiniz?

Gelecekte kullanımına yönelik öneriler ?

İnternette alışveriş yapıp E-ticaret yaparken parolamızın başkası tarafından ele geçirilmesi durumunda neler olabilir?

Parolalara alternatif kimlik doğrulama yöntemleri hakkında neler biliyorsunuz?

Parola kullanmadan kimliği nasıl doğrulanabileceğine ilişkin fikirler?

Biyometrik kimlik doğrulama yöntemlerinden örnekler (örn. parmak izi, yüz, ses, retina, iris, el geometrisi tanıma) başka örnekler?

Parola kullanımı ile biyometrik kimlik doğrulama yaklaşımları karşılaştırması? avantaj ve dezavantajları ?

Muhammed Emin Korkunc